VajraKavach

Secure Job Search & Professional Networking Platform

Project Milestone 2 Report

CSE 345/545: Foundations to Computer Security

Team Members	Roll Number
Yash Kumar Vaibhav	MT25091
Aayush Gupta	MT25008
Ayush Jain	MT25066
Ayush Kumar	2020290

Indraprastha Institute of Information Technology, Delhi

February 27, 2026

Contents

1 Secure User Registration and Login **2**
1.1 Overview . . . 2
1.2 Registration Flow . . . 2
1.3 Login Flow . . . 2
1.4 Security Features . . . 3
1.5 Screenshots . . . 3

2 TOTP Verification **5**
2.1 Overview . . . 5
2.2 TOTP Setup Flow . . . 5
2.3 TOTP Verification on Login . . . 5
2.4 TOTP for High-Risk Actions . . . 5
2.5 Screenshots . . . 6

3 User Profile Management **7**
3.1 Overview . . . 7
3.2 Profile Fields . . . 7
3.3 Profile Features . . . 7
3.4 Screenshots . . . 8

4 Secure Resume Upload with Encryption **10**
4.1 Overview . . . 10
4.2 Upload Flow . . . 10
4.3 Access Control . . . 10
4.4 Encryption Details . . . 10
4.5 Screenshots . . . 11

5 Basic Admin Dashboard **12**
5.1 Overview . . . 12
5.2 Admin Capabilities . . . 12
5.3 Role-Based Access Control (RBAC) . . . 12
5.4 Screenshots . . . 13

6 Summary **14**

Secure User Registration and Login

Overview

VajraKavach implements a multi-layered authentication system with industry-standard security practices. The registration and login flow ensures no plaintext passwords are ever stored or transmitted unnecessarily.

Registration Flow

1. User submits email, full name, password, and role (job_seeker / recruiter).
2. **Server-side validation:** Email format, password strength (minimum 8 chars, must contain uppercase, lowercase, digit, and special character).
3. **Password hashing:** Password is hashed using **Argon2id** (memory-hard, resistant to GPU/ASIC attacks) via the `passlib` library.
4. **PKI key pair generation:** An RSA-2048 key pair is generated for the user. The public key is stored in plaintext; the private key is encrypted with **Fernet (AES-128-CBC)** before storage.
5. **TOTP secret generation:** A unique TOTP secret is generated using `pyotp` and stored for subsequent two-factor authentication.
6. User record is created in PostgreSQL with all security fields populated.

Login Flow

1. User submits email and password.
2. Server retrieves the user record and verifies the password against the Argon2id hash.
3. On success, a **JWT access token** (HS256, 30-minute expiry) is issued.
4. The JWT payload includes the user ID, role, and **client IP address** for session binding.
5. A refresh token (7-day expiry) is also issued for seamless session renewal.
6. The `get_current_user` dependency validates the JWT on every protected request and verifies the IP matches the token's bound IP (preventing session hijacking).

Security Features

Feature	Implementation
Password Hashing	Argon2id (memory: 65536 KB, iterations: 3, parallelism: 4)
JWT Tokens	HS256, 30-min access / 7-day refresh
IP Binding	Client IP embedded in JWT, validated on each request
Rate Limiting	Account suspension after repeated failures
Input Validation	Pydantic schemas with strict email/password rules

Table 1: Authentication Security Summary

Screenshots

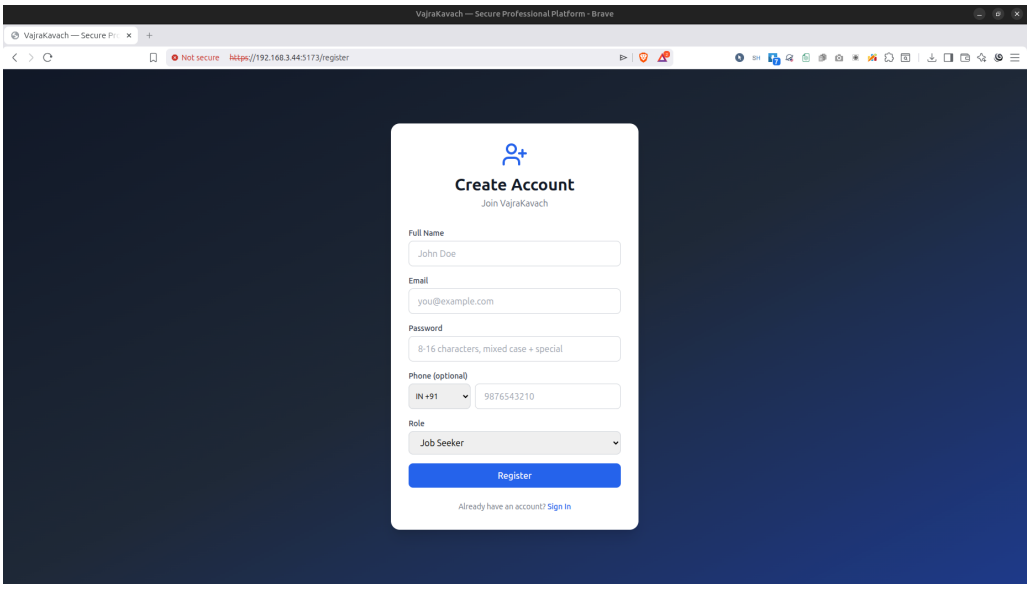


Figure 1: User registration page with email, name, password, and role selection

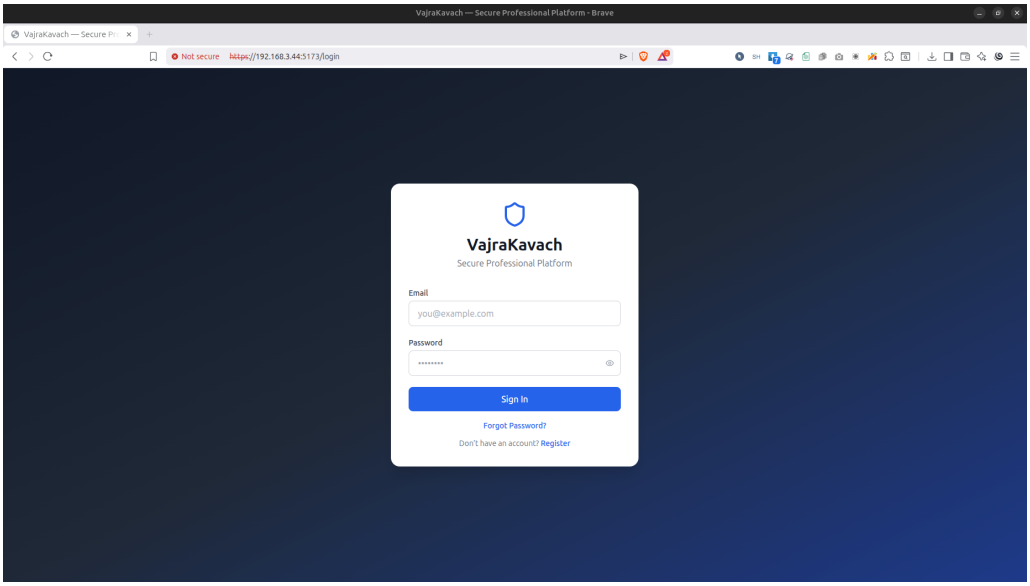


Figure 2: Login page with email and password fields

TOTP Verification

Overview

Time-based One-Time Password (TOTP) is implemented as a **mandatory second factor** after login. Users must set up TOTP during their first login and verify it on every subsequent login.

TOTP Setup Flow

1. After first login, the user is presented with a QR code containing their TOTP secret.
2. The QR code is generated server-side using the `qrcode` library and follows the `otpauth://` URI standard.
3. User scans the QR code with an authenticator app (Google Authenticator, Authy, etc.).
4. User enters a 6-digit TOTP code to verify setup.
5. On successful verification, the TOTP is marked as verified in the database.

TOTP Verification on Login

1. After email/password validation, the server checks if TOTP is verified.
2. User is prompted to enter the current 6-digit TOTP code.
3. Server validates the code using `pyotp.TOTP.verify()` with a ± 1 window tolerance.
4. On success, a new JWT token is issued with full authentication status.

TOTP for High-Risk Actions

TOTP verification is additionally required for:

- **Resume download:** Recruiters must enter TOTP before downloading any candidate's resume.
- **Resume deletion:** Users must verify TOTP before deleting their own resume.
- **Password change:** Current password + TOTP required.

Screenshots

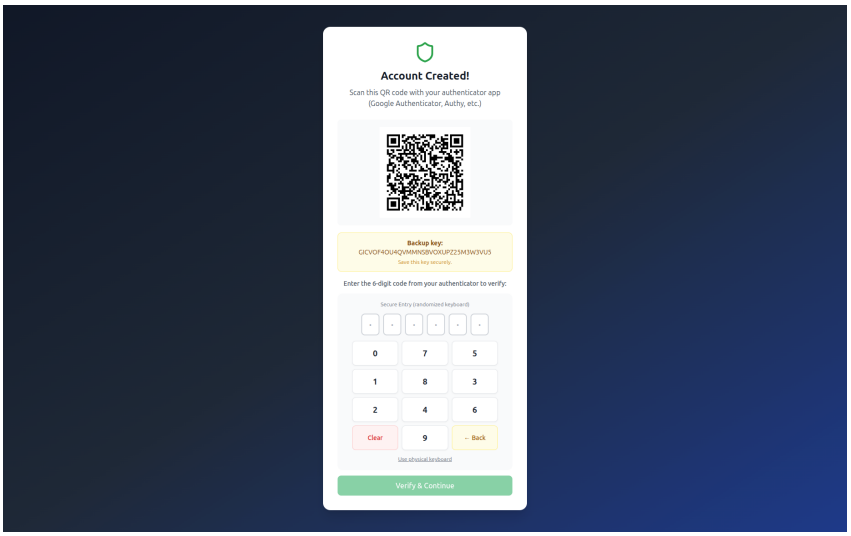


Figure 3: TOTP setup screen showing QR code for authenticator app

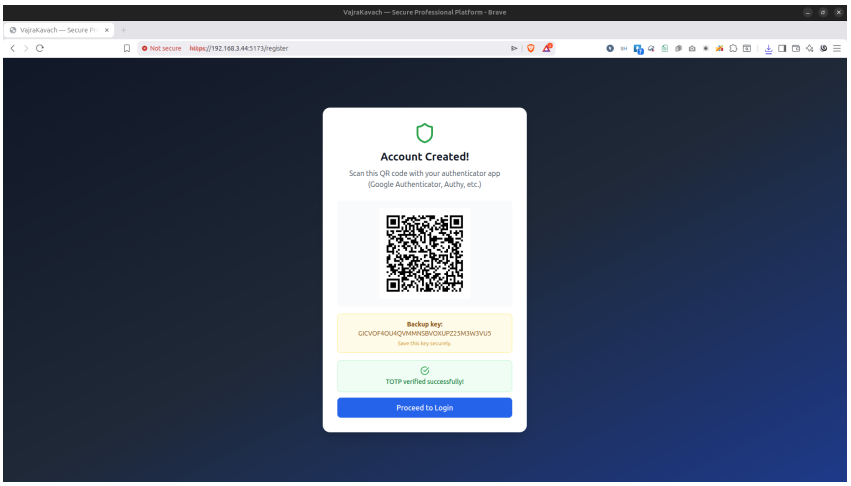


Figure 4: TOTP verification prompt during login

User Profile Management

Overview

Users can create and manage rich professional profiles with field-level privacy controls.

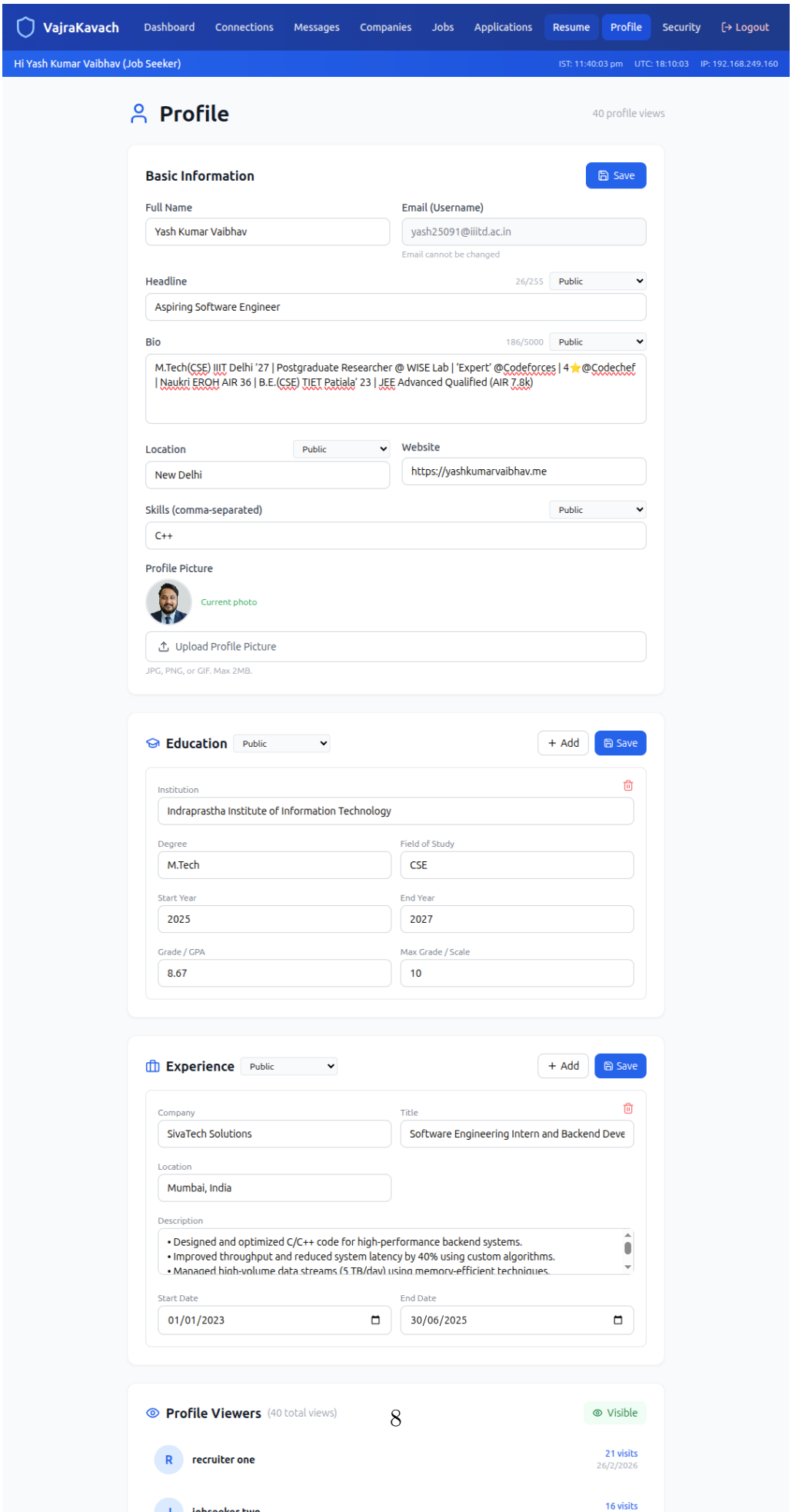
Profile Fields

- **Basic Info:** Full name, headline, location, bio, phone number.
- **Professional:** Education entries, experience entries, skills list.
- **Avatar:** Profile picture upload (JPEG/PNG, max 2 MB, stored as base64).
- **Privacy Controls:**
  - Profile visibility: Public / Connections-only / Private.
  - Show profile viewers: opt-in/opt-out toggle.

Profile Features

- **Profile view tracking:** Each profile visit is recorded (with 30-second deduplication cooldown). Users can see recent viewers if opted in.
- **Connection system:** Users can send/accept/reject/remove connection requests. The connection graph is restricted to direct connections only.
- **Public profiles:** Other users can visit a profile page (`/profile/:userId`) to view allowed fields.

Screenshots



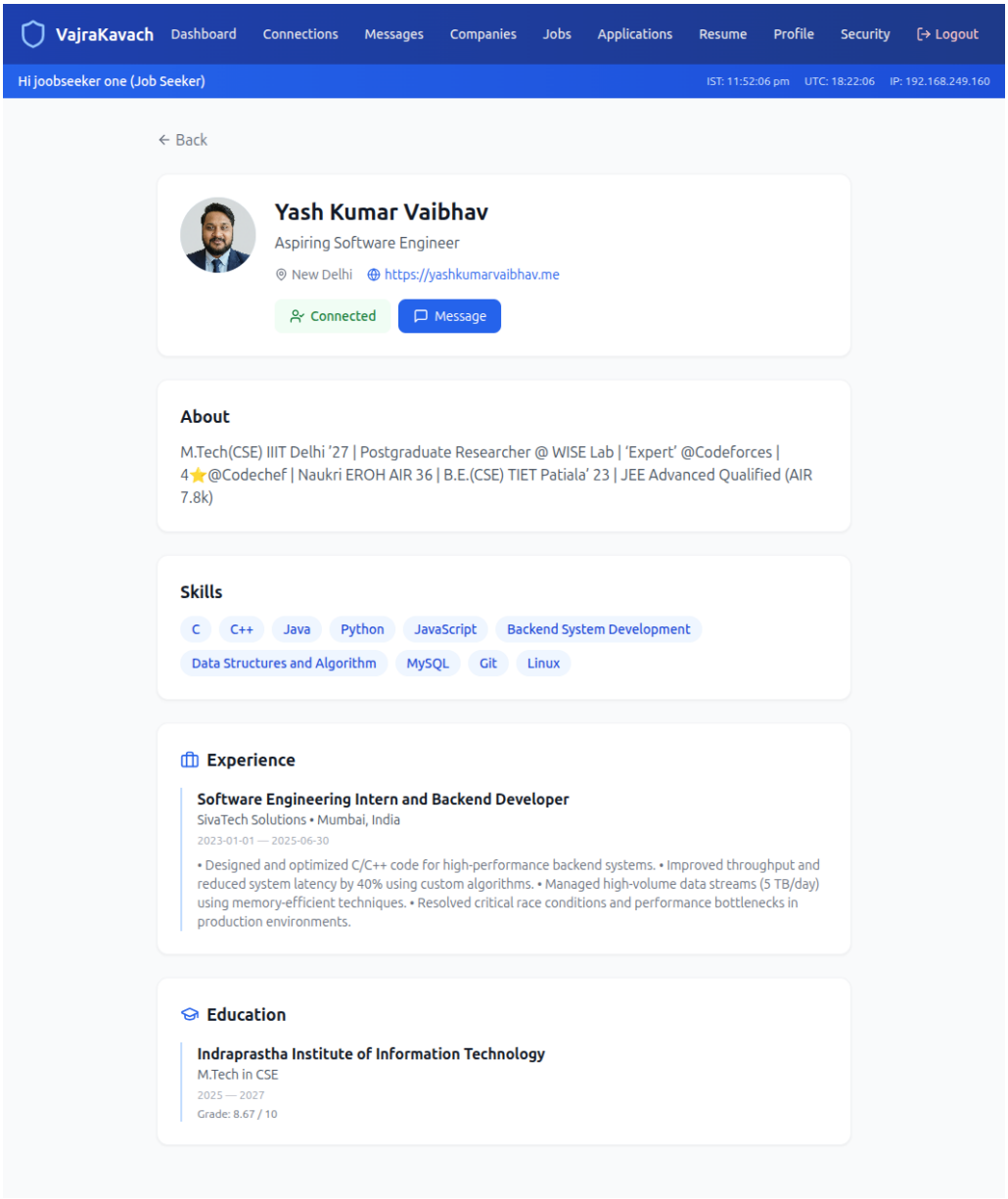


Figure 6: Public profile view as seen by another user

Secure Resume Upload with Encryption

Overview

Resumes are treated as sensitive assets. All uploaded resumes are encrypted at rest and subject to strict access control.

Upload Flow

1. User uploads a PDF or DOCX file (max 10 MB).
2. The server validates the MIME type (`application/pdf`, `application/vnd.openxmlformats...`)
3. The file content is encrypted using **Fernet symmetric encryption** (AES-128-CBC with HMAC-SHA256 for integrity).
4. The encrypted blob is written to disk at `backend/encrypted_resumes/`.
5. Metadata (original filename, MIME type, file size, encrypted path) is stored in PostgreSQL.

Access Control

Role	View/Download	Delete
Resume Owner	Yes (TOTP for download)	Yes (TOTP required)
Recruiter (of applied job)	Yes (TOTP for download)	No
Platform Admin	Yes (TOTP for download)	Yes
Other Users	No	No

Table 2: Resume Access Control Matrix

Encryption Details

- **Algorithm:** Fernet (AES-128-CBC + HMAC-SHA256).
- **Key:** Stored in server environment configuration (never in source code).
- **At rest:** Only ciphertext is stored on disk. Decryption happens on-the-fly at download time.
- **TOTP gate:** Every download request requires a valid TOTP code, preventing unauthorized bulk access even with a valid session.

Screenshots

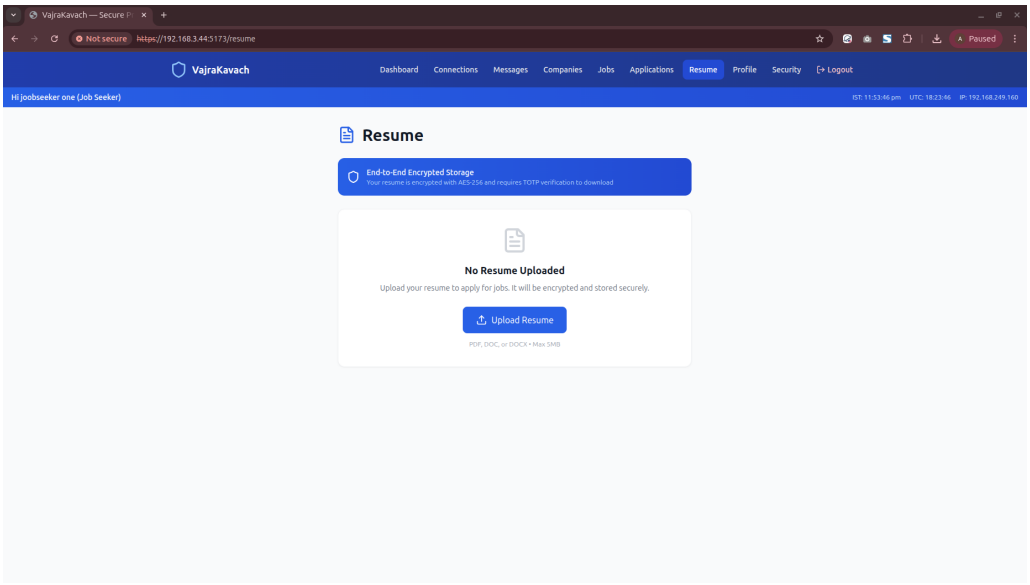


Figure 7: Resume upload interface showing file selection and upload button

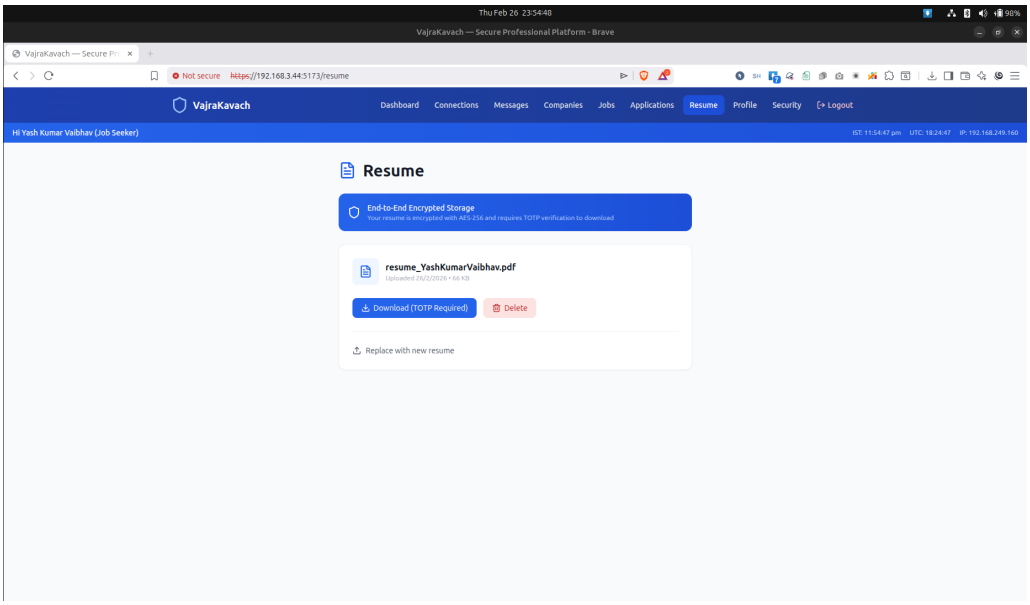


Figure 8: User's uploaded resumes with download (TOTP-gated) and delete options

Basic Admin Dashboard

Overview

The platform includes a dedicated admin dashboard accessible only to users with the `admin` role. It provides centralized management of users, jobs, resumes, announcements, reports, and audit logs.

Admin Capabilities

- **Overview Tab:** Summary statistics — total users, active users, jobs, applications, resumes, messages.
- **User Management:**
  - View all registered users with search and role filtering.
  - Suspend or reactivate user accounts.
  - Delete user accounts.
  - Role-based access control (RBAC): Regular User, Recruiter, Admin.
- **Job Management:** View and delist job listings.
- **Resume Management:** View all uploaded resumes with download capability (TOTP-gated).
- **Announcements:** Post encrypted announcements visible to all users.
- **Reports:** Review user reports (spam, harassment, fraud, etc.) and take action (review, resolve, dismiss).
- **Audit Logs:** View tamper-evident logs of all critical actions with hash chaining.

Role-Based Access Control (RBAC)

Action	Job Seeker	Recruiter	Admin
View own profile	✓	✓	✓
Apply to jobs	✓		
Post jobs		✓	
Manage users			✓
View audit logs			✓
Suspend accounts			✓

Table 3: RBAC Permission Matrix

Screenshots

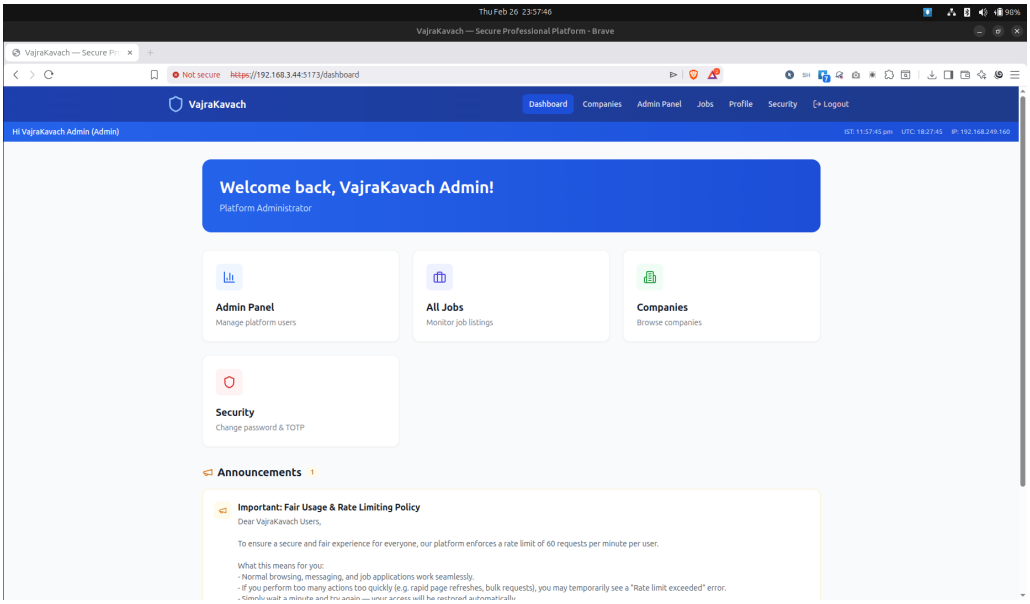


Figure 9: Admin dashboard overview showing platform statistics

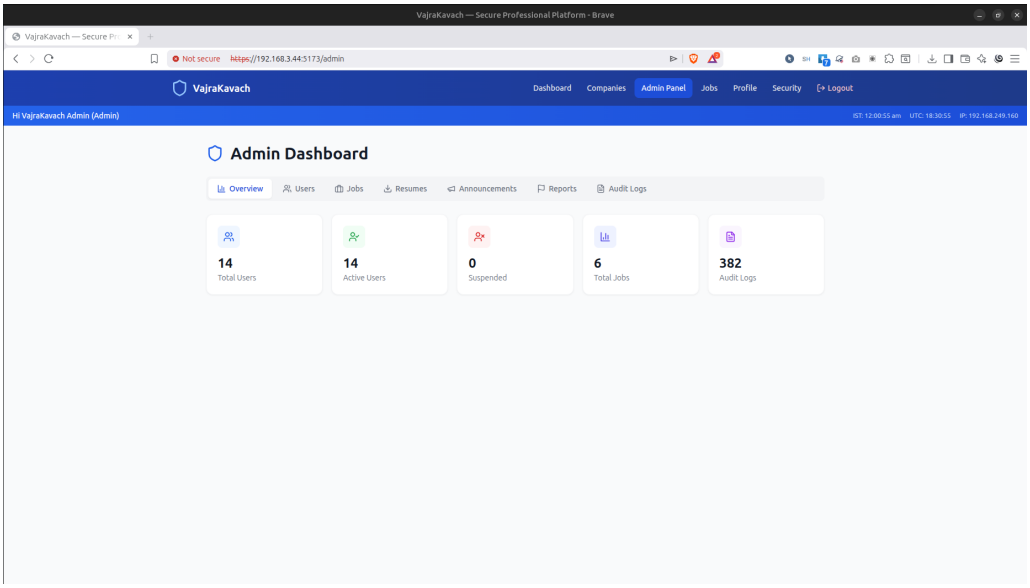


Figure 10: Admin user management panel with search, suspend, and delete controls

Summary

Milestone 2 delivers the core authentication and user management features of VajraKavach:

1. **Secure Registration & Login** — Argon2id password hashing, JWT tokens with IP binding, Pydantic input validation.
2. **TOTP Two-Factor Authentication** — Mandatory TOTP setup and verification on login, plus TOTP gates on high-risk actions (resume download/delete, password change).
3. **User Profile Management** — Rich profiles with education, experience, skills, avatar upload, field-level privacy controls, and profile view tracking.
4. **Encrypted Resume Storage** — Fernet AES encryption at rest, strict RBAC access control, TOTP-gated downloads.
5. **Admin Dashboard** — Centralized management of users, jobs, resumes, announcements, reports, and audit logs with role-based access control.

All security measures follow best practices as outlined in the course requirements. The codebase is version-controlled and ready for Milestone 3 (company pages, job workflows, messaging, and initial audit logging).

Repository: https://github.com/yashkumarvaibhav/VajraKavach